TABLA COMPARATIVA DE RESULTADOS — OWASP ZAP

Comparación entre el primer informe (ANTES) y el informe nuevo (Despues).

Alerta encontrada	Riesgo	Primer informe	Resultado en el nuevo informe
CSP: Directiva Wildcard	Medio	Detectada	Corregida
CSP: Failure to Define Directive with No Fallback	Medio	Detectada	Corregida
CSP: script-src unsafe-inline	Medio	Detectada	Corregida
CSP: style-src unsafe-inline	Medio	Detectada	Corregida
Configuración Incorrecta Cross-Domain	Medio	Detectada	Corregida
Cookie Sin Flag de Seguridad	Bajo	Detectada	Corregida
El servidor filtra información de versión a través del campo "Server"	Bajo	Detectada	Continúa en el informe
Falta encabezado X-Content-Type-Options	Bajo	Detectada	Corregida
Strict-Transport-Security Header No Establecido (HSTS)	Bajo	Detectada	Continúa en el informe
Aplicación Web Moderna	Informativo	Detectada	Continúa en el informe
Divulgación de información - Comentarios sospechosos	Informativo	Detectada	Continúa en el informe
Reexaminar las Directivas de Control de Caché	Informativo	Detectada	Corregida
Respuesta de Gestión de Sesión Identificada	Informativo	Detectada	Continúa en el informe

Alerta que permanece	Riesgo	Motivo por el que continúa
Divulgación de la versión del servidor (Server)	Bajo	Server. Es necesario revisar la configuración del servidor que genera la respuesta para reducir esa divulgación.
Falta del encabezado HSTS	Bajo	entorno de desarrollo. Por eso, puede no aparecer cuando se analiza la aplicación localmente.
Aplicación web moderna	Informativ	es informativa y no implica necesariamente una vulnerabilidad que deba corregirse.
Divulgación de información por comentarios sospechos	Informativ	exponen información sensible. Si contienen información interna, deberán eliminarse o modificarse.
Respuesta de gestión de sesión identificada	Informativ	requiere evaluación, pero por sí sola no demuestra que exista una vulnerabilidad.

Después del segundo análisis realizado con OWASP ZAP, algunas alertas continúan presentes porque todavía requieren ajustes en la configuración del servidor, revisión de los encabezados de seguridad o análisis del contenido detectado. En particular, la alerta relacionada con HSTS puede estar vinculada a que la aplicación se ejecuta en un entorno de desarrollo, mientras que la divulgación de la versión del servidor requiere revisar el encabezado HTTP correspondiente.

Por otra parte, las alertas informativas relacionadas con aplicaciones web modernas y gestión de sesiones no representan necesariamente vulnerabilidades explotables. Por ello, se deben documentar y evaluar según la evidencia proporcionada por ZAP. Las alertas que permanecen deberán revisarse mediante pruebas adicionales antes de determinar si requieren una corrección.